

SOC 2 & HIPAA Security Readiness Assessment

Azure Healthcare Security Landing Zone | Technical Portfolio Assessment

Purpose: evaluate the implemented Azure controls against selected SOC 2 Trust Services Criteria and HIPAA Security Rule safeguard areas, document evidence, identify gaps, and define production-hardening priorities.

Executive Summary

This assessment reviews a healthcare-focused Azure landing zone built to protect a modeled clinical workload. The environment implemented preventive, protective, and detective controls across governance, identity, networking, encryption, data protection, and centralized logging. Controls were tested through negative deployment tests and generated administrative activity rather than being accepted solely because they were configured.

The environment demonstrates strong technical readiness in Azure governance, network segmentation, private service access, customer-managed encryption, audit logging, and change detection. It is **not presented as HIPAA compliant or SOC 2 certified**. Production readiness would require additional organizational, operational, physical, vulnerability-management, resilience, and continuous-assurance controls.

Assessment Scope

In Scope	Out of Scope / Not Demonstrated
Azure Management Groups and Policy Azure RBAC Hub-spoke networking and NSGs Private Link / Private DNS Key Vault and customer-managed keys Storage data protection Azure Monitor / Log Analytics KQL security-control change detection Defender for Cloud Foundational CSPM	Production application compute Clinical ePHI or real patient data Facility and workstation physical controls Formal workforce training program Business Associate Agreements Enterprise vulnerability scanner coverage Formal disaster-recovery exercise Independent SOC 2 examination Legal HIPAA compliance determination

Overall Readiness

Area	Assessment	Summary
Azure technical safeguards	Implemented	Strong lab evidence for access boundaries, encryption, private connectivity, logging and governance.
Operational security program	Partial	Incident-response concepts and auditability demonstrated; formal procedures, ownership and recurring testing remain.
Vulnerability management	Partial	CSPM visibility present, but continuous workload vulnerability scanning and remediation SLAs were not demonstrated.
Physical / workforce safeguards	Gap / Out of Scope	Require organizational processes beyond this Azure technical lab.
Compliance determination	Not claimed	This is a readiness exercise, not an attestation, certification or legal determination.

HIPAA Security Rule Readiness Checklist

HHS organizes the Security Rule around administrative, physical, and technical safeguards, with additional organizational and documentation requirements. The checklist below maps the lab to those safeguard areas at a practical readiness level.

HIPAA safeguard area	Status	Project evidence / assessment
Risk analysis & risk management	Partial	Security readiness review identified technical gaps and production improvements. A formal enterprise-wide ePHI risk analysis was not performed.
Assigned security responsibility	Out of scope	The lab demonstrates security administration but does not establish an organizational HIPAA Security Official.
Workforce security & information access management	Partial	Azure RBAC and separation of duties were implemented. Production should add PIM/JIT, access reviews, joiner-mover-leaver processes and formal authorization procedures.
Security awareness & training	Gap	No workforce security-awareness or HIPAA training program was part of the technical lab.
Security incident procedures	Partial	Centralized logs, KQL detection and an investigation workflow were demonstrated. Formal escalation, communications, evidence handling and tabletop testing remain.
Contingency planning	Partial	Blob/container soft delete, versioning and change feed were enabled. Formal backups, application recovery, RPO/RTO and disaster-recovery testing remain.
Periodic evaluation	Implemented / Partial	Controls were deliberately tested, failures investigated, scope drift corrected and logging validated. Production requires recurring scheduled evaluations.
Facility / workstation / media safeguards	Out of scope	Physical access, workstation security and media disposal require organizational controls outside this Azure landing-zone lab.
Access control	Implemented	RBAC, managed identity, segmented networks and private endpoints reduce unauthorized access paths.
Audit controls	Implemented	Subscription Activity Logs and resource diagnostics were centralized in Log Analytics and validated through generated activity.
Integrity	Implemented / Partial	CMK encryption, versioning, soft delete and change feed support data integrity and recovery. Application-level integrity controls were not assessed.
Person/entity authentication	Partial	Entra-based identities and Azure RBAC were used. Full production MFA/Conditional Access validation was outside the evidence set.
Transmission security	Implemented	TLS 1.2, secure transfer, Private Link and private DNS were used to reduce exposure of data in transit.
Policies, procedures & documentation	Partial	Technical evidence and control rationale are documented in the repository. Formal HIPAA policies, retention, approvals and six-year compliance documentation processes were not established.

HIPAA readiness conclusion: The project provides meaningful evidence for several technical safeguards, especially access control, auditability, transmission security, and protection of stored data. HIPAA compliance, however, also depends on administrative, physical, organizational, documentation, and risk-management processes that cannot be satisfied by Azure configuration alone.

SOC 2 Trust Services Criteria Readiness Checklist

SOC 2 examinations use the AICPA Trust Services Criteria. Security is foundational; Availability, Processing Integrity, Confidentiality, and Privacy are additional categories selected according to the service and engagement. This lab primarily demonstrates technical controls relevant to Security and Confidentiality, with supporting readiness evidence for Availability.

Trust Services area	Status	Project evidence / assessment
Security - logical access	Implemented / Partial	Azure RBAC, managed identities and network boundaries were implemented. Production should add PIM/JIT, recurring access reviews and stronger privileged-access lifecycle controls.
Security - system boundaries	Implemented	Management Groups, approved-region policy, tagging policy, hub-spoke design, NSGs and Private Link establish governance and network boundaries.
Security - change monitoring	Implemented	Azure Activity Logs were centralized and a KQL query was validated against a policy-assignment deletion to identify critical control changes.
Security - risk mitigation	Partial	Negative testing and remediation were performed. Continuous vulnerability scanning, formal risk register ownership and remediation SLAs remain.
Security - monitoring	Implemented / Partial	Log Analytics and Foundational CSPM were used. Production should add broader workload telemetry, alerting, response automation and continuous monitoring.
Availability	Partial	Storage recovery features were configured, but formal service availability targets, capacity planning, backup strategy, RPO/RTO and DR testing were not established.
Confidentiality	Implemented / Partial	Private endpoints, TLS, Key Vault, CMK encryption and restricted access support confidentiality. Data classification, retention and enterprise DLP were outside scope.
Processing Integrity	Out of scope / Partial	Infrastructure controls were assessed, but no production application transaction processing existed to evaluate completeness, validity, accuracy, timeliness or authorization of processing.
Privacy	Out of scope / Partial	No real PHI was used. Privacy notices, consent, collection, use, retention, disclosure and data-subject processes were not assessed.
Evidence & auditability	Implemented	Repository evidence, policy source, KQL detection, screenshots and control-testing results provide traceable technical evidence for the lab.

Evidence Highlights

Control objective	Validation evidence
Prevent unauthorized deployment	Azure Policy blocked a West US 2 deployment and an untagged workload deployment.
Protect sensitive services	Storage and Key Vault used Private Link; Storage public network access was disabled.
Protect encryption keys	Storage used a customer-managed RSA key in Key Vault through a user-assigned managed identity.
Restrict east-west traffic	NSGs modeled Web -> App over 443 and App -> Data over 1433 with deny rules for other VNet inbound traffic.
Audit administrative activity	Generated Azure administrative activity was located in the centralized Log Analytics workspace.
Detect security-control changes	KQL detected an Azure Policy assignment deletion and exposed actor, operation, resource, time, result and source IP.
Validate governance scope	Compliance review exposed a subscription-scoped tagging assignment; the assignment was corrected to the Landing-Zones scope.

Production Readiness Gaps & Priorities

The following items are intentionally recorded as gaps rather than being hidden by the lab. They represent the controls I would prioritize before treating a similar healthcare environment as production-ready.

Priority	Production action	Why it matters
1	Privileged access hardening	Replace standing privileged access with PIM/JIT where appropriate; add approval, MFA/Conditional Access validation and recurring access reviews.
2	Formal vulnerability management	Implement continuous scanning, risk-based prioritization, remediation SLAs, exception handling, ownership and rescan validation.
3	Centralized traffic inspection	Add Azure Firewall or equivalent with UDR-based routing, egress controls, threat intelligence and appropriate network logging.
4	Backup & recovery engineering	Define RPO/RTO, backup retention, restore procedures, dependency recovery order and scheduled recovery tests.
5	Incident-response operations	Define severity, ownership, escalation, communications, containment authority, evidence handling and tabletop exercises.
6	Compliance operations	Maintain formal risk analysis, policies, workforce training, BAAs where applicable, control owners, evidence retention and recurring evaluations.
7	Data governance	Classify sensitive data, define retention, minimize access, evaluate DLP, and disable Storage Shared Key where compatibility permits.

Assessment Conclusion

The landing zone demonstrates a defensible technical security foundation for a modeled healthcare workload. Its strongest evidence is not the number of Azure resources deployed, but the control-validation process: preventive policies were negatively tested, a policy/platform compatibility failure was investigated and redesigned, policy scope drift was detected and corrected, and centralized logging was validated with real administrative activity.

The environment should therefore be described as **security-readiness aligned**, not compliant or certified. A production healthcare deployment would require the technical controls in this lab to operate as part of a broader governance, risk, workforce, physical-security, vulnerability-management, incident-response, resilience, and evidence-retention program.

Reference Basis

- U.S. Department of Health & Human Services (HHS), Summary of the HIPAA Security Rule - current rule summary and administrative, physical, and technical safeguard structure.
- HHS Office for Civil Rights, Guidance on Risk Analysis - risk analysis as a foundational Security Rule activity.
- AICPA & CIMA, 2017 Trust Services Criteria (with revised points of focus - 2022) - Security, Availability, Processing Integrity, Confidentiality, and Privacy criteria.

Important: This document is a portfolio-based technical readiness assessment using synthetic resources and data. It is not a SOC 2 report, attestation, HIPAA certification, legal opinion, or independent compliance assessment.